

Módulo 4: Arquitecturas y protocolos de seguridad. Tema 2: Cortafuegos y VPNs

Cortafuegos

¿Qué es un cortafuegos?

Un cortafuegos (o firewall) es un sistema de red que separa y controla el tráfico existente entre redes, permitiendo o denegando la comunicacin entre ellas.

Se trata de un dispositivo (físico o lógico) que filtra el tráfico mediante unas reglas de filtrado que deciden que paquetes pueden pasar a la red interna desde la externa y viceversa.

Hay dos tipos de cortafuegos: Cortafuegos de aplicación y cortafuegos.

Nivel TCP/IP	Protocolos principales	Dispositivo
Aplicación	HTTP, DNS	Cortafuegos de aplicación, IDS
Transporte	TCP, UDP, ICMP	Cortafuegos
Red	IP	Cortafuegos, Router
Enlace	ARP, Ethernet	Switch, Hub

Reglas

Cada paquete que llega al dispositivo es comparado con las reglas, en orden hasta encontrar una coincidencia. Al encontrar una coincidencia se ejecuta la acción asociada a ella (denegar, aceptar, restringir, etc.).

Si no hay ninguna coincidencia, se aplica la política por defecto: tráfico permitido o tráfico prohibido. La política por defecto de tráfico prohibido (DENY ALL) se considera la más segura

Ejemplo:

Regla	Acción	IP Origen	Puerto Origen	IP Destino	Puerto Destino	Protocolo	Descripción
1	ALLOW	10.0.0.0/24	ANY	ANY	ANY	ICMP	Permite tráfico ICMP de salida
2	ALLOW	10.0.0.0/24	ANY	ANY	ANY	TCP	Permite conexiones TCP de salida
3	ALLOW	ANY	ANY	10.0.0.1	80	TCP	Permite la conexión con el servidor Web
4	DENY	ANY	ANY	10.0.0.0	ANY	ANY	Por defecto, rechaza cualquier otra conexión a la red interna

Políticas por defecto

- Denegación por defecto (DENY ALL): Más costosa de mantener, ya que es necesario indicar explícitamente todos los servicios que tienen que permanecer abiertos (los demás, por defecto, serán denegados).
- Aceptación por defecto (ACCEPT ALL): Es más sencilla de administrar, pero incrementa el riesgo de permitir ataques contra nuestra red, puesto que requiere indicar explícitamente qué paquetes es necesario descartar (los demás, por defecto, serán aceptados en su totalidad).

Cortafuegos de aplicación

Se diferencia de un cortafuegos tradicional en que entiende el nivel de aplicación. Esto significa que puede tomar decisiones basándose en los parámetros de la capa de aplicación, como HTTP, DNS, etc.

Mientras que un cortafuegos a nivel de red o transporte filtra tráfico basándose en direcciones IP, puertos, tipos de protocolo y flags, un cortafuegos de aplicación va más allá.

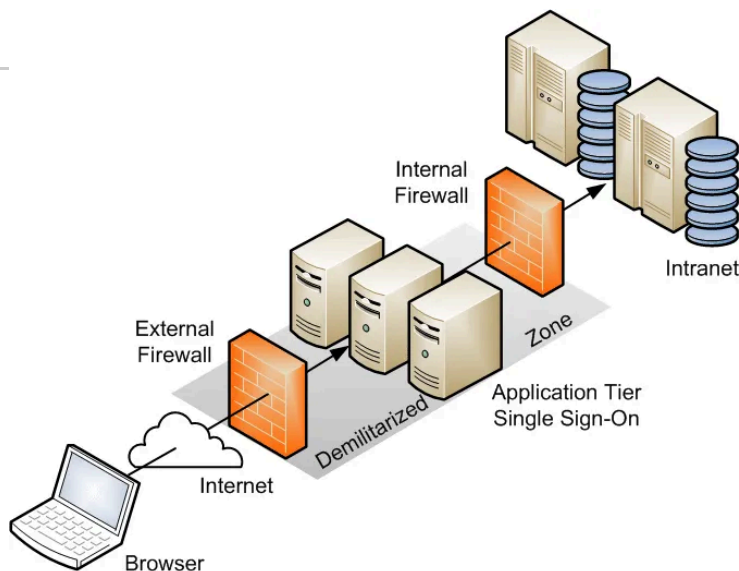
Algunos ejemplos de las decisiones y acciones que un cortafuegos de aplicación puede realizar incluyen:

- Filtrar ataques de inyección SQL en peticiones HTTP. La fuente muestra un ejemplo de cómo se vería una petición HTTP "envenenada" con un ataque de inyección SQL (SQLi) y menciona que la detección podría hacerse con una regla, aunque la sintaxis concreta dependerá del fabricante. Los servidores son puntos críticos y si se compromete uno con SQLi, puede usarse para "saltar" a otras máquinas cercanas (ataque de desplazamiento lateral).
- Bloquear el acceso a secciones específicas de un sitio web en función de la dirección IP o de los encabezados.
- Redirigir el tráfico a una página de mantenimiento.
- Evitar que los bots de los motores de búsqueda accedan a un sitio web.

Redes DMZ

La necesidad de una DMZ (DeMilitarized Zone) surge porque, en una topología tradicional con un único cortafuegos, un error o vulnerabilidad en ese cortafuegos puede dejar toda la red interna expuesta. Además, los servidores son un punto crítico; si uno se ve comprometido, puede utilizarse para saltar a otras máquinas cercanas, lo que se conoce como ataque de desplazamiento lateral.

El diseño de la red DMZ implica separar el exterior de la red de la DMZ. Aquí se sitúan los servidores públicos que deben ser accedidos desde Internet. Un cortafuegos se configura para rechazar todas las conexiones entrantes a la red interna desde la DMZ. De esta manera, si un servidor en la DMZ es comprometido, el ataque queda contenido en esa zona y no puede acceder fácilmente a la red interna.



VPNs

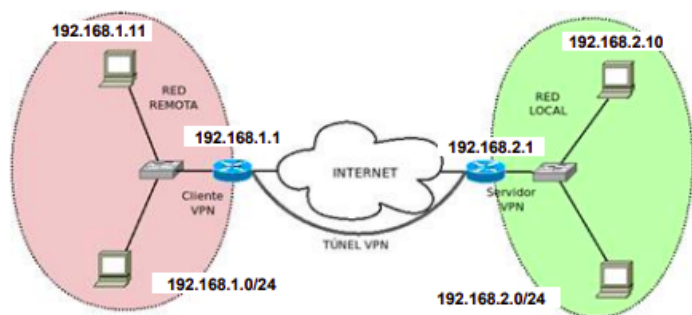
Una red privada virtual (VPN) es una arquitectura que aúna dos tipos de tecnologías:

- Métodos criptográficos para asegurar la comunicación.

- Protocolos de encapsulamiento (túneles) de tráfico que permiten que, en lugar de una conexión física dedicada para la red privada, se puede utilizar una infraestructura de red pública para definir sobre ella una red virtual.

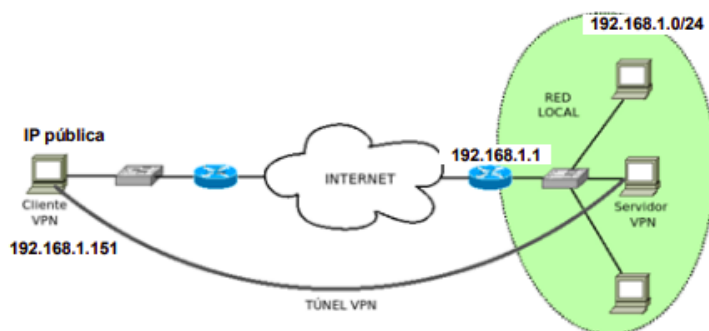
Tipos

Red-red (site-site)



Conexión entre dos redes remotas, a través de un túnel que se establece entre los routers.

Acceso remoto (cliente-red)



Una vez establecido el túnel, el cliente obtiene una IP de la red interna y pertenece de forma “lógica” a ella. El cliente dispondrá de dos interfaces “virtuales”: uno con su IP pública, y otro con la IP privada de la VPN.

Protocolos

- Point-to-Point Tunneling Protocol (PPTP): Funciona a nivel de enlace. Diseñado para conexiones sencillas, únicas entre cliente y servidor (no permiten conectar dos redes).
- Layer 2 Tunneling Protocol (L2TP): Este protocolo es una combinación del anterior, PPTP, y el antiguo Layer 2 Forwarding Protocol (L2F).
 - IPSec
 - Es el estándar más completo, pues permite todo tipo de conexiones, incluyendo túneles que conectan dos redes completas, en lugar de dos computadores.
 - Inconveniente: puede llegar a ser difícil de configurar.

WireGuard

Wireguard es una implementación ligera de un protocolo VPN que destaca por su sencilla configuración, que se realiza mediante archivos simples y legibles. Está implementado como un módulo del kernel de Linux para un alto rendimiento e integración, aunque también existen implementaciones para otros sistemas operativos como Windows, macOS y Android.

Arquitectura

- Cada dispositivo (peer) tiene una clave pública y una privada
- La comunicación es peer-to-peer, aunque se puede simular un modelo cliente-servidor.
- Las conexiones se establecen automáticamente cuando hay tráfico ("silent until needed").
- Se basa en el protocolo UDP, lo que lo hace eficiente y más resistente a cortafuegos.

Deep Web - Dark Web

Web abierta	Deep Web	Dark Web
- Contenido indexado por los motores de búsqueda. - Accesible con navegadores tradicionales. - Supone menos del 5% del contenido total de datos.	- Contenido "privado" o no indexado. - Es, simplemente, contenido no accesible por los motores, como bases de datos, intranets, etc. - No se sabe con precisión, pero puede suponer alrededor del 90% de los datos en Internet.	- Contenido no indexado y solo accesible con protocolos específicos, como Tor. - Aunque hay contenido legal, lo cierto es que la mayoría es ilícito.